Justificativa Técnica: Arquitetura Cloud Segura

Integrantes: Jhonny Emanoel, Milton Magalhães e Nayara Medeiros

1. Visão geral

A aplicação web (interface, API, banco de dados e envio de arquivos) foi migrada para a AWS (região us-east-1) em uma VPC `10.0.0.0/16`, distribuída em duas Availability Zones. Somente o ALB e o NAT Gateway ficam em sub-redes públicas. A aplicação e o banco ficam em sub-redes privadas e não recebem conexões diretas da internet. O acesso administrativo é feito por VPN com MFA, e todas as ações e o tráfego são registrados para auditoria.

2. Por que cada componente foi incluído

Componente	Por que foi incluído
Route 53	Resolve o domínio da aplicação para o ALB.
AWS WAF	Filtra ataques web (SQL injection, XSS, excesso de requisições) antes de chegarem à aplicação.
ALB + ACM	Recebe o HTTPS (443), encerra o TLS com certificado do ACM e distribui as requisições entre as duas AZs.
Internet Gateway	Única porta de entrada e saída da VPC para a internet.
NAT Gateway	Permite que recursos privados baixem atualizações sem receber conexões de fora.
EC2/ECS (API e aplicação)	Processa as requisições dos clientes, em sub-rede privada.
RDS Multi-AZ (PostgreSQL)	Armazena os dados, com réplica em outra AZ para disponibilidade.
S3	Armazena os arquivos enviados pelos usuários, com acesso controlado.
VPC Gateway Endpoint (S3)	Mantém o tráfego entre a aplicação e o S3 dentro da rede da AWS.
Client VPN	Permite a administração dos recursos internos sem expô-los.
IAM Roles e MFA	Dão às aplicações e aos administradores só as permissões necessárias.
Secrets Manager	Guarda a senha do banco fora do código.
KMS	Gerencia as chaves de criptografia do RDS, do S3 e dos segredos.
CloudTrail	Registra quem fez qual ação na conta.
VPC Flow Logs	Registra o tráfego de rede aceito e rejeitado.
CloudWatch	Centraliza logs, métricas e alarmes.

Componente	Por que foi incluído
GuardDuty	Detecta comportamento suspeito automaticamente.

3. Sub-redes públicas e privadas

Camada	Sub-rede	Motivo
ALB e NAT Gateway	Pública (`10.0.1.0/24` e `10.0.2.0/24`)	O ALB precisa receber tráfego da internet e o NAT precisa de saída para ela.
API/App	Privada (`10.0.11.0/24` e `10.0.12.0/24`)	Só precisa ser acessada pelo ALB. Sem IP público e sem rota de entrada da internet.
RDS	Privada (`10.0.21.0/24` e `10.0.22.0/24`)	O banco só precisa ser acessado pela aplicação. É o componente mais sensível e não tem rota para a internet.

Cada camada fica em sub-rede e Security Group próprios. Se um componente for comprometido, o atacante não alcança as outras camadas livremente.

4. Conexões permitidas e bloqueadas

As conexões completas estão em `fluxos.md`. Em resumo:

Permitidas

- Cliente → WAF/ALB: HTTPS 443.
- ALB → App: HTTP 8080.
- App → RDS: TCP 5432.
- App → S3: HTTPS 443, pelo VPC Endpoint.
- App → Secrets Manager e CloudWatch: HTTPS 443.
- Administrador → Client VPN: 443.
- VPN → App (SSH 22) e VPN → RDS (5432).
- App → Internet, via NAT: HTTPS 443, só para atualizações.

Bloqueadas

- Internet → App.
- Internet → RDS.
- Internet → SSH/RDP.
- Acesso público ao S3 (Block Public Access).
- RDS → Internet.

Como o bloqueio é aplicado

- **Security Groups encadeados:** cada SG só aceita tráfego do SG anterior, e não de faixas de IP.
  - `sg-alb` aceita 443 de `0.0.0.0/0`.
  - `sg-app` aceita 8080 só de `sg-alb` e 22 só de `sg-vpn`.
  - `sg-rds` aceita 5432 só de `sg-app` e `sg-vpn`.
- **Tabelas de rotas:** as sub-redes privadas não têm rota de entrada da internet.

- **Security Groups são stateful:** a resposta a uma conexão permitida volta automaticamente. Por isso o `sg-rds` não precisa de regra de saída.

5. Proteção do acesso administrativo

- Nenhuma porta de administração (SSH 22 ou RDP 3389) fica aberta para a internet.
- O administrador entra pela **Client VPN**, com autenticação por certificado ou SSO e **MFA**.
- Depois de conectado, só o `sg-vpn` pode acessar o SSH da aplicação e o banco.
- O usuário root não é usado no dia a dia e tem MFA.
- O **SSM Session Manager** é uma alternativa equivalente: não exige nenhuma porta aberta e registra as sessões.
- Todas as ações administrativas ficam registradas no CloudTrail.

6. Limitação de permissões (menor privilégio)

- A aplicação usa uma **IAM Role** (instance profile ou task role), sem chaves de acesso fixas no código.
- A Role da aplicação permite apenas:
  - `s3:GetObject` e `s3:PutObject` no bucket específico da aplicação.
  - `secretsmanager:GetSecretValue` no segredo do banco.
  - `kms:Decrypt` na chave usada.
  - Envio de logs ao CloudWatch.
- A Role não tem permissão de exclusão no bucket, nem permissões administrativas.
- Os administradores usam usuários ou perfis próprios com MFA, separados por função (por exemplo, quem só consulta logs não altera rede).
- A bucket policy do S3 aceita apenas acessos vindos do VPC Endpoint e da Role da aplicação.

7. Redução dos riscos de exposição de dados e de acesso não autorizado

Risco	**Como a arquitetura reduz**
Banco acessado pela internet	O RDS fica em sub-rede privada, sem IP público e com `sg-rds` restrito.
Arquivos expostos	O S3 usa Block Public Access, política restrita ao endpoint e criptografia com KMS.
Interceptação de dados	O TLS no ALB protege o tráfego em trânsito. O RDS e o S3 usam criptografia em repouso (KMS).
Ataques à aplicação web	O WAF filtra requisições maliciosas antes do ALB.
Vazamento de credenciais	A senha do banco fica no Secrets Manager, e não no código.
Movimentação lateral	Os Security Groups encadeados limitam cada camada ao necessário.
Acesso administrativo indevido	VPN com MFA, sem portas de administração abertas na internet.
Falha de uma AZ	O ALB, a aplicação e o RDS Multi-AZ estão distribuídos em duas AZs.

8. Como os registros de auditoria ajudam a identificar atividades suspeitas

Serviço	O que registra	Exemplo de atividade suspeita detectada
CloudTrail	Ações de API e de usuários na conta	Alteração de política IAM, criação de usuário, mudança em Security Group, login sem MFA.
VPC Flow Logs	Tráfego aceito e rejeitado	Varredura de portas, tentativas de acesso ao banco vindas de origem inesperada.
GuardDuty	Análise automática de CloudTrail, Flow Logs e DNS	Credenciais usadas de local incomum, comunicação com IP malicioso.
CloudWatch	Logs da aplicação, métricas e alarmes	Muitos erros 4xx/5xx, picos de falhas de login, alarme enviado à equipe.

Os registros permitem investigar um incidente (quem fez, quando e de onde) e gerar alertas antes que ele cause danos maiores.

9. Mecanismos específicos

VPN (Client VPN)

- **Problema que resolve:** a equipe precisa administrar recursos privados (aplicação e banco) sem abrir SSH ou RDP para a internet.
- **Por que é adequado:** o acesso passa por um túnel criptografado, autenticado e com MFA. Só quem está conectado à VPN alcança as portas de administração, por meio do `sg-vpn`.

VPC Gateway Endpoint (S3)

- **Problema que resolve:** sem ele, o tráfego da aplicação para o S3 sairia pelo NAT Gateway e pela internet pública.
- **Por que é adequado:** o tráfego vai pela rede interna da AWS, sem passar pela internet. Isso reduz a exposição e o custo com NAT, e permite restringir o bucket para aceitar apenas o endpoint (`aws:SourceVpce`).

10. Conclusão

A arquitetura atende aos 9 requisitos do enunciado: acesso HTTPS com WAF e ALB, banco e aplicação isolados em sub-redes privadas, arquivos em S3 com acesso controlado, administração por VPN com MFA, comunicações limitadas por Security Groups encadeados, auditoria com CloudTrail, Flow Logs, GuardDuty e CloudWatch, e permissões por IAM Roles com menor privilégio.